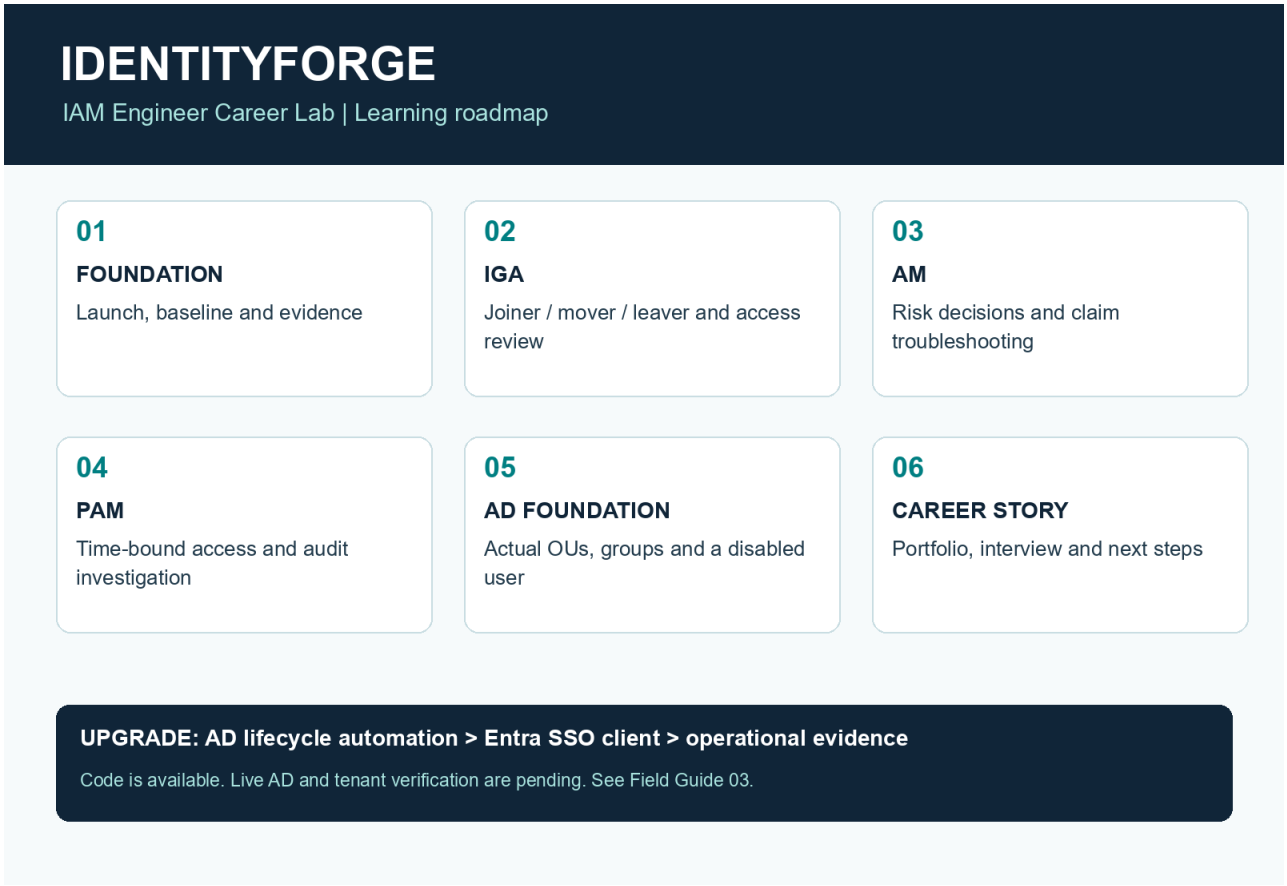
FIELD GUIDE 01 / SELF-PACED TRAINING

IdentityForge

IAM Engineer Career Lab

Getting started & step-by-step handbook

Build repeatable identity workflows. Capture evidence. Explain your decisions.



YOUR STARTING POINT

Windows 11 host / 16 GB RAM / PowerShell 5.1. Start with the standalone track. Add an isolated Windows Server domain when ready for actual AD.

ORIENTATION

Choose the right track

Track	What you can do now	Requirement
Standalone	All three scenarios, evidence exports, reset, interview practice	Windows PowerShell; no cloud account
Actual AD	Foundation plus CSV lifecycle, activation, reconciliation and audit scripts	Dedicated Windows Server AD domain; live verification pending
Entra SSO	MSAL client, tenant setup and application mapping break/fix; Field Guide 03	Lab tenant; live sign-in pending

What is installed - and what is not

The folder contains scripts and learning material. It does not install a virtual machine, AD DS, an identity provider, a secure vault or cloud synchronization. Standalone actions change only local exercise files.

Find your materials

Start-Lab.cmd is the formatted launcher. WORKBOOK.md contains the exercises; ANSWER-KEY.md contains solutions; INTERVIEW.md contains five practice questions. The advanced folder contains the actual AD checkpoint. output/pdf contains these guides; output/images contains a roadmap and eight image-layout references.

Recommended reading order

1. First launch and evidence routine. 2. Standalone workbook exercises. 3. Optional Windows Server preparation and AD checkpoint. 4. Roadmap and LinkedIn playbook. 5. Answer key after your attempt.

COMPLETION RULE

A green progress check is not the whole milestone. Keep screenshots, before/after exports and a short explanation. Advanced cloud and PAM work must not be described as deployed when it is only planned or designed.

QUICK START

Your first 15 minutes

1. Open the project folder

Open the Senior IAM Engineer Mentor & Lab Instructor folder supplied with this guide. Keep its folder structure intact.

2. Launch IdentityForge

Double-click Start-Lab.cmd. Choose 1 for this handbook, 2 for the portfolio playbook, or 3 to launch the simulation.

3. Inspect the baseline

In the practice console choose 1. Expect three directory identities and four HR records. No real Windows accounts are modified.

4. Capture before evidence

Choose 2 before applying IGA rules. Copy evidence/access-review.csv to a dated folder as access-review-before.csv. Capture the baseline console.

5. Start the IGA exercise

Edit workspace/rules.json in Notepad following the workbook. Save it, then choose 3 to apply. Continue with the step-by-step workbook pages that follow.

6. Resume any time

Choose Q to return to the launcher. Close it with Q. Your workspace persists automatically; relaunching does not reset your work.

EXPECTED FIRST FINDINGS

Jordan has conflicting payment privileges. Taylor is terminated in HR but remains enabled. These are intentional defects to investigate and fix.

WORKING ROUTINE

Evidence, reset and troubleshooting

A repeatable evidence routine

Create evidence/Attempt-01 (or a date plus attempt number). Keep baseline and after reports, screenshots, a decision log and lessons learned there. Menu 2 and menu 4 overwrite their fixed CSV filenames, so copy each result before rerunning.

Use Windows + Shift + S to capture a focused region. Save PNGs with names such as 01-baseline.png, 02-iga-after.png and 03-policy-results.png. Crop personal paths and never include passwords, recovery codes or live tokens.

Reset only when ready

Inside the simulation choose R, then type RESET. This replaces working state and editable rules. It retains evidence, but later exports can overwrite reports at their original paths. It does not delete actual AD objects or reset a domain.

If PowerShell blocks startup

The launcher keeps your normal script policy. On your personal lab device, the following starts a new PowerShell process with a process-only execution setting. It does not change the saved policy. Organization controls take precedence.

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -File .\Lab.ps1
```

Other common issues

Invalid JSON: check commas, quotes and brackets, or compare against ANSWER-KEY.md. Missing mapping: fill every department array before applying IGA. Expired fixture token: follow the workbook renewal note. Active JIT grant: finish its expiry test before requesting another. Missing PDF: verify output/pdf exists. Missing AD module/domain: use the standalone track until Windows Server setup is complete.

Ollama is optional. The core exercises do not call a model or use the network. A reachable Ollama API does not verify model inference or guarantee that a cloud-tagged model stays local.

STANDALONE / STEP-BY-STEP EXERCISE

0. Environment

Launch Start-Lab.cmd and choose 3 to open the practice console. Inside that console, select 1. Confirm three directory identities and four HR records. Verify `workspace/state.json` and `evidence/audit.jsonl` exist. The working directory is your mock directory; department codes represent OUs: HR = HR, ENG = Engineering, FIN = Finance, SUP = Support. OUs organize identities; group membership represents authorization.

Gate: screenshot the baseline and record the difference between HR truth and directory state. All screenshots should show synthetic data only; crop personal paths.

STANDALONE / STEP-BY-STEP EXERCISE

1. IGA: lifecycle and compliance

Business context: terminations remain active, department transfers accumulate access, and Finance has conflicting payment privileges. You own provisioning and certification evidence.

1. Select 2 **before applying any rules**. Preserve `evidence/access-review.csv` as `access-review-before.csv`. Identify the two high-risk findings. Write who should approve remediation and what evidence closes each finding.

2. Open `workspace/rules.json`. Fill the department arrays using this mapping:

Code	Birthright groups
HR	AllEmployees, HR-Portal
ENG	AllEmployees, Engineering-Tools
FIN	AllEmployees, Finance-Read
SUP	AllEmployees, Support-Tickets

3. Explain your rule in plain language: an active employee receives exactly their department's managed birthright groups; terminated employees are disabled and lose all simulated access. Unknown department mappings must fail for review.

4. Select 3. Inspect Casey's new account, Alex's Support-to-Engineering move, and Taylor's disabled account. Note that this lab treats every group as managed by the reconciliation engine. Production systems must distinguish birthright groups from approved exceptional access rather than erase all grants indiscriminately.

5. Select 2 again. Save the clean report as `access-review-after.csv`. Explain why automated remediation does not replace owner certification. In this exercise Jordan's conflicting grants are removed by full birthright reconciliation; a real certification workflow would record an owner decision before revoking exceptional grants.

6. Select 3 a second time. Confirm no duplicate identities or groups. Reconciliation should converge on the same state, although audit events are still appended.

7. Select 9. IGA should be True.

Gate: retain before/after CSVs, directory screenshot, rule screenshot, and a short explanation of mover removal, leaver revocation, idempotency, and separation of duties.

LinkedIn draft prompt: "Write 120 words about my simulated IGA lab. Explain the stale-account and privilege-creep problems, HR-driven birthright mapping, removal of old mover access, and a payment creator/approver conflict. Use only results I observed. Clearly call it a local simulation. Include one lesson about audit evidence."

2. AM: federation reasoning and adaptive access

Business context: many separate logins and reused passwords cause account takeover risk. Your job is to understand federation boundaries, implement risk decisions, and isolate a claim failure.

1. Sketch this simulated flow: user -> application -> IdP -> returned token -> application validation -> session. Label issuer, audience, subject, expiry, signing verification, and mandatory application claims. Real OIDC uses authorization code flow with PKCE where applicable, plus state/nonce checks; this fixture only exercises claim reasoning.

2. Select 4. Record the intentionally unsafe policy results and missing-email error.

3. Edit `workspace/access-policy.json`. Use these decisions: HighRisk = Block; Unmanaged = Block; CorporateManaged = Allow; RemoteManaged = RequirePhishingResistantMFA. High risk must override corporate location. Corporate IP alone is not proof of trust: the seamless case also assumes an already authenticated session on a managed device satisfying baseline controls.

4. Select 4. Confirm all four policy cases show Pass = True. The MFA result is a policy decision, not an actual MFA challenge.

5. Open `workspace/state.json`. Find Token and set Email to `alex.morgan@example.invalid`. Preserve valid JSON. Select 4 again. If the lab has been idle more than 24 hours, the token can also be expired: set ExpiresUtc to a future UTC timestamp and document that this represents issuing a new fixture, not bypassing expiry on a real token.

6. Write a troubleshooting record: symptom, issuer/audience checks, expiry, mandatory claim, mapping correction, and retest. Explain why a valid signature alone would not fix a missing claim. Real tokens require cryptographic verification against trusted keys; never trust an edited token.

7. Select 9. AM should be True. Also retain the token-check screenshot; the progress check alone does not verify every token property.

Gate: policy results CSV, claim-error screenshot, corrected-check screenshot, flow sketch, and troubleshooting record.

LinkedIn draft prompt: "Describe a day in my simulated IAM analyst lab: integrate an application conceptually with an IdP, prioritize device/risk signals over IP location, require phishing-resistant MFA for a remote managed device, and troubleshoot a missing claim. Explicitly distinguish simulated checks from a deployed IdP or real MFA."

STANDALONE / STEP-BY-STEP EXERCISE

3. PAM: JIT and privileged-session investigation

Business context: scripts contain standing admin passwords and vendors have unsupervised sessions. You must reduce standing privilege, document approval, and detect misuse.

1. Write a vault design with secret reference `vault://lab/break-glass`, named owner, emergency approval path, limited retrieval rights, access logging, rotation after use, and periodic recovery testing. Do not put a password in JSON. This is a vault-design exercise; no secure vault is installed by this environment.

2. Select 6: access should be denied before a grant.

3. Select 5. Enter a fictional change ticket and reason. Type APPROVE to simulate a second person's decision. Explain why typing both roles yourself is not real separation of duties.

4. Save the grant details. Verify ExpiresUtc minus StartUtc is exactly two hours. Select 6: access is allowed by the simulated grant.

5. Select 7 to advance the clock exactly two hours. Access should be denied at the expiry boundary. Select 6 again to confirm denial. Explain the difference between removing a role assignment, expiring a token, and terminating an existing admin session.

6. Select 8. Identify the unauthorized payroll export and audit-logging disable command. Create `evidence/incident-notes.txt`: timeline, affected identity/session, immediate containment, evidence preservation, secret/session revocation, escalation, scope investigation, and recovery criteria. Do not execute any command from the log.

7. Select 9. PAM should be True. This checks grant duration and expired status; review your incident notes and vault design separately.

Gate: deny/allow/expired screenshots, grant duration, vault design, and incident notes. Production JIT should grant the smallest task-specific role rather than default Domain Admin; the role name here is deliberately a high-risk simulation.

LinkedIn draft prompt: "Explain standing privileges versus my simulated two-hour JIT grant. Mention ticket justification, independent approval in a real implementation, authorization at expiry, session controls, and two suspicious audit events. Clearly state no real domain privileges or secure vault were deployed."

OPTIONAL ACTUAL AD / PREREQUISITE

Prepare Windows Server

This setup is performed manually in your isolated VM. Nothing below has been run on your host. Budget 2-4 hours for a first setup; actual timing depends on your machine and familiarity.

1. Choose virtualization

Use an available supported hypervisor. Hyper-V requires an eligible Windows edition and hardware virtualization; check the Microsoft guide linked below before enabling it. If your edition does not support it, use an appropriately licensed alternative. Do not change your host networking to accommodate a sample address.

2. Create one Windows Server VM

A practical starting allocation for this host is 2 vCPUs, 4 GB RAM and an 80 GB virtual disk, subject to the selected Server release requirements. Install a supported Windows Server Desktop Experience edition from official media. Avoid running large local models at the same time.

3. Isolate the exercise network

Create a private lab virtual switch and connect only the lab VM(s). Use its VM console for administration; no host domain join is needed. For a private switch with no other subnet, an example DC address is 192.168.77.10/24 with DNS pointing to itself and no gateway. Check for address conflicts first. If updates require internet, plan temporary controlled connectivity, then restore isolation before exercises.

4. Name and configure the server

Inside the VM, rename it DC01 using Server Manager > Local Server, restart, set the intended lab IP/DNS, and confirm time and storage. Keep the local administrator and future recovery passwords in a real password manager.

5. Install AD DS and create the forest

In Server Manager choose Add roles and features > Role-based installation > this server > Active Directory Domain Services. Include management tools and install. Select Promote this server to a domain controller > Add a new forest. Enter iamlab.test, keep DNS and Global Catalog, choose a DSRM password, review prerequisites and install. The server restarts. Perform this only in the disposable lab VM; never an existing business domain.

OPTIONAL ACTUAL AD / VERIFICATION

Verify the domain, then build

6. Verify the new lab

Sign in to the new lab domain, open Windows PowerShell with lab administrative rights and verify AD DS and DNS health before continuing. DSRM credentials are recovery credentials, not your normal domain sign-in.

```
Import-Module ActiveDirectory
Get-ADDomain | Select-Object DNSRoot, DistinguishedName
Get-Service NTDS,DNS,ADWS
Resolve-DnsName dc01.iamlab.test
dcdiag /test:DNS
```

Expected: iamlab.test is returned, directory/DNS/AD Web Services are running, and the DC name resolves to its intended lab address. Investigate diagnostic failures rather than ignoring them.

7. Copy the lab files into the VM

Transfer the project through your hypervisor supported file/ISO mechanism. Run the AD checkpoint from inside the VM. Take a supported lab checkpoint/backup before creating training objects; snapshots are not a production AD backup strategy.

8. Continue with Checkpoint 1

Use the next pages to preview and build the training tree. Keep cloud sync disabled. A routable verified cloud sign-in domain is a later design issue, not required for this local .test domain.

Official setup references

Install Hyper-V

Install Active Directory Domain Services

Install-ADDSForest reference

References checked October 18, 2026. VM sizing and the private-subnet example are lab design choices, not universal vendor requirements. Windows Server licensing or evaluation eligibility must be handled separately.

ACTUAL AD / FIRST EXECUTABLE CHECKPOINT

Create the AD training foundation

Goal: create a training OU tree, seven global security groups, and one disabled synthetic user. No cloud sync or real privileged access is configured.

A. Validate your AD environment

Run inside your dedicated lab Windows Server, or a management machine with the ActiveDirectory module and connectivity to that domain. Replace both sample values below with your lab DC FQDN and domain DNS name. Do not run until you have a dedicated test domain.

```
Get-Module -ListAvailable ActiveDirectory
Import-Module ActiveDirectory
$labDc = 'dc01.iamlab.test'
$labDomain = 'iamlab.test'
Get-ADDomain -Server $labDc |
    Select-Object DNSRoot, DistinguishedName, DomainMode
Get-ADDomainController -Identity $labDc -Server $labDc |
    Select-Object HostName, IsReadOnly, Site
```

Gate: the module loads, the returned domain is your dedicated lab domain, and the selected controller is writable. If not, stop here. Windows 11/Ollama validation does not satisfy this AD prerequisite.

B. Preview changes

Open PowerShell in this project's **advanced** folder (copy the folder into your VM if necessary). With the same two variables set:

```
.\01-Build-ADLab.ps1 -Server $labDc -ExpectedDomain $labDomain -WhatIf
```

Expect proposed creation of IAM-Training under the domain root, child OUs HR/Engineering/Finance/Support/Terminated/Groups, seven LAB-prefixed groups and lab-alex. The preview queries the real domain but does not create objects. Every creation must be confined to IAM-Training except creation of that root OU itself.

ACTUAL AD / APPLY AND VERIFY

Build and verify the training objects

Using a lab account delegated to create this OU tree (or the lab's administrative account):

```
.\01-Build-ADLab.ps1 -Server $labDc -ExpectedDomain $labDomain
```

The key creation commands used in the script are New-ADOrganizationalUnit, New-ADGroup and New-ADUser. New groups have no permissions on resources. The user is disabled with EmployeeID LAB-001 and Department Support; no password is embedded. Re-running skips existing expected objects and rejects name collisions outside the expected locations. It does not repair drift in existing object attributes.

Verify independently:

```
$labDn = 'OU=IAM-Training,' + (Get-ADDomain -Server $labDc).DistinguishedName
Get-ADOrganizationalUnit -SearchBase $labDn -Filter * -Server $labDc |
    Select-Object Name, DistinguishedName
Get-ADGroup -SearchBase $labDn -Filter * -Server $labDc |
    Select-Object Name, GroupCategory, GroupScope
Get-ADUser -Identity lab-alex -Properties EmployeeID,Department -Server $labDc |
    Select-Object SamAccountName,Enabled,EmployeeID,Department,DistinguishedName
```

Expected: seven OUs including IAM-Training, seven Global/Security groups, and lab-alex disabled in Support with the expected attributes. Repeat the build and verify that objects were not duplicated. The script specifies -Server on each AD call to keep operations on the chosen DC.

Evidence: screenshot the OU tree in Active Directory Users and Computers, group output and disabled-user attributes. Save in a dated evidence subfolder. Crop host/domain details if necessary. Record why OUs are different from authorization groups and why a local UPN is not proof of cloud synchronization.

Stop and verify this checkpoint before continuing. No birthright assignments, cloud synchronization, account enabling or privileged elevation occurs here. After verification, continue independently with **lifecycle/README.md**, starting with its preview-only checkpoint. Do not rerun this foundation builder after moving lab-alex; use the lifecycle reconciliation workflow instead.

FINISH STRONG

Your completion checklist

[ ] Standalone baseline captured before remediation.

[ ] IGA: joiner, mover, leaver, before/after certification and repeat-run evidence.

[ ] AM: four passing policy cases, claim rejection/correction and troubleshooting notes.

[ ] PAM: denied / approved / expired evidence, incident notes and vault design.

[ ] Menu 9 outcomes checked; written limitations explain what those checks do not cover.

[ ] Optional actual AD: verified OUs, groups and disabled test user, clearly separated from simulation.

[ ] Interview: five recorded answers, self-scores and one improvement for each.

[ ] Portfolio: only verified accomplishments, dated artifacts and sanitized public images.

NEXT STEP

Use Field Guide 03 for implemented AD lifecycle scripts, the Entra SSO client and operational evidence. Live AD and tenant verification remain pending. Use the Roadmap and LinkedIn Playbook for verified accomplishments; tiered privileged AD automation is still a future extension.

Keep the editable sources

The Markdown workbook and answer key remain alongside this PDF. The portfolio playbook also has an editable Markdown copy. Start-Lab.cmd opens the guides without sending your work anywhere.